

Sistema de exámenes médicos Cuidarte+

Especificación de requerimientos de Software

Historial de versiones

Fecha	Versión	Autor	Descripción
01/04/2026	1.0	Sebastián Rojas	Creación de documento de especificación de Software.
13/04/2026	1.1	Roberto Araya	Se añaden especificaciones en requerimientos funcionales y no funcionales.

HISTORIAL DE VERSIONES.....	1
1 INTRODUCCIÓN	3
1.1 Propósito	3
1.2 Alcance	3
1.3 Definiciones, acrónimos y abreviaturas	3
1.4 Resumen	4
2 DESCRIPCIÓN GENERAL.....	4
2.1 Perspectiva del producto	4
2.2 Funcionalidad del producto	4
2.3 Características de los usuarios	5
2.4 Restricciones	5
2.5 Suposiciones y dependencias	5
3 REQUISITOS ESPECÍFICOS.....	5
3.1 Requisitos comunes de los interfaces	5
3.1.1 Interfaces de usuario (Frontend).....	5
3.1.2 Interfaz de servidor (Backend)	6
3.2 Requisitos funcionales	6
RF-1 Autenticación y sesión	6
RF-2 Registro de usuarios	6
RF-3 Gestión de exámenes médicos	8
RF-4 Visualización de información médica	8
RF-5 Auditoría.....	9
3.3 Requisitos no funcionales	10
3.3.1 Seguridad (NFR-SEG)	10
3.3.2 Rendimiento (NFR-PERF)	10
3.3.3 Usabilidad y accesibilidad (NFR-USAB)	10
3.3.4 Disponibilidad y mantenimiento (NFR-DIS)	10
3.3.5 Compatibilidad (NFR-COMPAT).....	10
3.4 Reglas de negocio (RB)	10
4. Arquitectura de la solución.....	11
4.1 Front-end.....	11
4.2 Back-end	11

1 Introducción

1.1 Propósito

Este documento describe los requerimientos funcionales y no funcionales del sistema Cuidarte+, una plataforma web orientada a centros de salud para la gestión de pacientes, exámenes médicos y documentos clínicos. Está dirigido a desarrolladores, testers, analistas de seguridad y stakeholders del proyecto.

1.2 Alcance

Cuidarte+ permitirá a médicos registrar pacientes y exámenes médicos, a pacientes visualizar su información clínica y a administradores supervisar, auditar y administrar usuarios y datos del sistema, adicionalmente se debe garantizar el cumplimiento de normativa de protección de datos y estándares de seguridad. Debe ser accesible desde desktop, tablets y móviles, con especial atención a la usabilidad para adultos mayores.

1.3 Definiciones, acrónimos y abreviaturas

Concepto	Definición
Atlas	Nombre de la plataforma web de gestión de clientes, contratos desarrollada por CreaLAB.
SRS	Software Requirements Specifications
API	Interfaz de programación de aplicaciones (RESTful JSON)
RUT	Rol Único Tributario (identificador en Chile)
AuthN / AuthZ	Autenticación / Autorización
Admin	Rol con permisos completos sobre datos
Editor	Rol con permisos de sólo visualización según requerimiento
DB	Base de datos PostgreSQL
Frontend	Capa visual del sistema, desarrollada en React, que interactúa con los usuarios finales.
Backend	Lógica de negocio y API del sistema, desarrollada en Node.js con Express, que interactúa con la base de datos y maneja las reglas del sistema.
React	Librería de Javascript utilizada para construir interfaces de usuario reactivas y componentes reutilizables.
Express	Framework minimalista de Node.js utilizado para construir la API REST del backend.
PostgreSQL	Sistema de gestión de base de datos relacional de código abierto, orientado a alta confiabilidad y cumplimiento ACID.
TSL (Transport Layer Security)	Protocolo criptográfico que garantiza la privacidad e integridad de los datos en tránsito

Hashing	Técnica criptográfica para transformar contraseñas o datos sensibles en valores irreversibles (usualmente usando algoritmos como bcrypt o Argon2).
Bcrypt	Algoritmo de Hashing diseñado para proteger contraseñas mediante sal aleatoria y alto costo computacional.
Endpoint	Punto de acceso (RUL) expuesto por la API que recibe y responde a solicitudes de los clientes
JWT (Json web token)	Formato estándar de token usado para autenticar usuarios y transmitir información de forma segura entre cliente y servidor.
CRUD	Operaciones básicas de persistencia de datos: Create, Read, Update, Delete.
SPA (Single Page Application)	Aplicación web que carga una sola página HTML y actualiza dinámicamente el contenido sin recargar la página completa, mejorando la experiencia del usuario.
CSRF (Cross-site Request forgery)	Tipo de ataque que fuerza a un usuario autenticado a ejecutar acciones no deseadas.
XSS (Cross-site Scripting)	Ataque que inyecta scripts maliciosos en páginas vistas por otros usuarios.
SQL Injection	Ataque que manipula consultas SQL mediante entrada no validada
Backup	Copia de seguridad periódica de la base de datos o archivos para prevenir pérdida de información
Uptime	Porcentaje de tiempo que el sistema está disponible y operativo

1.4 Resumen

El documento continúa con una descripción general del producto, lista de requerimientos funcionales y no funcionales, interfaces externas, restricciones, criterios de aceptación y una matriz de trazabilidad con el esquema de BD.

2 Descripción general

2.1 Perspectiva del producto

Cuidarte+ es una aplicación web multicapa: Frontend (React) consume API RESTful (Express) que opera sobre PostgreSQL. El sistema centraliza la gestión de pacientes, exámenes médicos, documentos clínicos y auditoría de acciones.

2.2 Funcionalidad del producto

- Autenticación y gestión de sesión
- Registro de nuevos usuarios
- Gestión de pacientes (datos personales y médicos)
- Gestión de exámenes médicos
- Carga y visualización de documentos médicos
- Registro de auditoría de acciones de usuarios
- Interfaz responsiva y accesible
- Seguridad, control de acceso, cifrado, login seguro, backups.
- Acceso diferenciado según rol

2.3 Características de los usuarios

Cada usuario debe pertenecer a una o más empresas

Administrador	Administra usuarios, edita cuentas, gestiona exámenes y revisa auditoría
Médico	Registra y gestiona pacientes y exámenes médicos
Paciente	Visualiza sus exámenes y documentos asociados
Usuario anónimo / visitante	Sólo accede al flujo de registro, sin acceso a datos.

2.4 Restricciones

- El stack tecnológico debe ser una capa de cliente con React, capa de servidor con Express y base de datos PostgreSQL.
- Almacenamiento de documentos (PDF u otros) en storage interno con referencia en BD.
- Soporte para múltiples tamaños de pantalla y dispositivos
- Política de contraseñas, mínimo configurable (por defecto: 12 caracteres, incluir mayúsculas, minúsculas, número y símbolo.
- Hashing de contraseñas en backend (bcrypt)
- Todas las comunicaciones deben usar TLS
- Los documentos deben estar fuertemente controlados por contener información sensible

2.5 Suposiciones y dependencias

- Los usuarios finales disponen de navegador moderno (Chrome, Firefox, Safari, Edge).
- Integración de correo electrónico para verificación y notificaciones
- Disponibilidad de almacenamiento suficiente para documentos.

3 Requisitos específicos

3.1 Requisitos comunes de los interfaces

3.1.1 Interfaces de usuario (Frontend)

- SPA en React, responsiva.
- Páginas principales:
 - Login
 - Registro
 - Dashboard según rol
 - Gestión de Usuarios
 - Gestión de Pacientes
 - Gestión de Exámenes médicos
 - Visualización/descarga de documentos
 - Auditoría
- Accesibilidad, tamaños de fuentes 12px, contraste suficiente, etiquetas ARIA en formularios, navegación por teclado, elementos de UI con tamaño mínimo para pantallas táctiles.

Criterios de aceptación: pruebas de usabilidad con usuarios mayores (5 usuarios representativos) no muestran bloqueos mayores y cumplimiento básico de accesibilidad.

3.1.2 Interfaz de servidor (Backend)

- Endpoints RESTful JSON para: auth (login, logout, refresh token), usuarios, pacientes, exámenes, documentos, roles y auditoría.
- Autenticación basada en JWTs de corta vigencia y refresh token (o sesión segura).
- Validación de entradas (server-side) para todos los Endpoints.

Criterios de aceptación: colección con swagger con test básicos y cobertura de endpoints críticos.

3.2 Requisitos funcionales

RF-1 Autenticación y sesión

Número de requisito	RF-1.1
Nombre de requisito	El sistema debe permitir a un usuario autenticarse con nombre_usuario y contraseña
Tipo	Requisito
Prioridad del requisito	Alta/Esencial

Número de requisito	RF-1.2
Nombre de requisito	El sistema debe soportar cierre de sesión y revocación de tokens
Tipo	Requisito
Prioridad del requisito	Alta/Esencial

Criterio de aceptación: Login exitoso genera un token de sesión (JWT); Logout invalida sesión;

RF-2 Registro de usuarios

Número de requisito	RF-2.1
Nombre de requisito	Los usuarios deben poder registrarse rápidamente ingresando usuario, contraseña y correo. Al confirmar su registro pueden acceder al sistema como rol "paciente" por defecto.
Tipo	Requisito
Prioridad del requisito	Alta/Esencial

Número de requisito	RF-2.2
---------------------	--------

Nombre de requisito	Un usuario médico o administrador puede registrar a un paciente para que pueda ingresar exámenes médicos
Tipo	Requisito
Prioridad del requisito	Alta/Esencial

Número de requisito	RF-2.3
Nombre de requisito	Un usuario médico o administrador puede editar el registro de un paciente para actualizar su información
Tipo	Requisito
Prioridad del requisito	Alta/Esencial

Número de requisito	RF-2.4
Nombre de requisito	Un usuario médico o administrador puede visualizar el registro de un paciente
Tipo	Requisito
Prioridad del requisito	Alta/Esencial

Número de requisito	RF-2.5
Nombre de requisito	Un usuario administrador puede visualizar los usuarios registrados en la plataforma para administrar o gestionar
Tipo	Requisito
Prioridad del requisito	Alta/Esencial

Número de requisito	RF-2.6
Nombre de requisito	Un usuario administrador editar un usuario permitiendo adicionalmente establecer distintos roles
Tipo	Requisito
Prioridad del requisito	Alta/Esencial

Número de requisito	RF-2.7
Nombre de requisito	Un usuario administrador puede eliminar un usuario de la plataforma

Tipo	Requisito
Prioridad del requisito	Alta/Esencial

RF-3 Gestión de exámenes médicos

Número de requisito	RF-3.1
Nombre de requisito	Un usuario médico puede registrar un nuevo examen a un paciente para llevar registro de sus antecedentes médicos
Tipo	Requisito
Prioridad del requisito	Alta/Esencial

Número de requisito	RF-3.2
Nombre de requisito	Un usuario médico puede editar tanto los datos del examen como modificar o actualizar los documentos médicos
Tipo	Requisito
Prioridad del requisito	Alta/Esencial

Número de requisito	RF-3.3
Nombre de requisito	Un usuario médico puede eliminar el examen médico o los documentos cargados a él.
Tipo	Requisito
Prioridad del requisito	Alta/Esencial

Criterios de aceptación: Operaciones CRUD funcionan y validan correctamente el ingreso u edición. Se debe realizar una eliminación lógica solicitando al usuario confirmación antes de proceder en la operación.

RF-4 Visualización de información médica

Número de requisito	RF-4.1
Nombre de requisito	Un usuario paciente puede visualizar sus exámenes médicos para visualizar su registro médico.
Tipo	Requisito
Prioridad del requisito	Alta/Esencial

Número de requisito	RF-4.2
Nombre de requisito	Un usuario paciente puede descargar los documentos de sus exámenes médicos para mantener una copia o respaldo de sus documentos médicos.
Tipo	Requisito
Prioridad del requisito	Alta/Esencial

Número de requisito	RF-4.3
Nombre de requisito	Los usuarios médicos pueden adjuntar un documento por registro de examen médico en formato PDF, DOC, PPT, JPG, PNG.
Tipo	Requisito
Prioridad del requisito	Alta/Esencial

Número de requisito	RF-4.4
Nombre de requisito	Los documentos deben almacenarse en storage interno y ser referenciados en la base de datos
Tipo	Requisito
Prioridad del requisito	Alta/Esencial

Criterios de aceptación: La subida y descarga debe considerar un tiempo no mayor a 10 segundos.

RF-5 Auditoría

Número de requisito	RF-5.1
Nombre de requisito	Registrar en auditoria las acciones críticas: creación, edición, eliminación de clientes, contratos, usuarios, subida o descarga de documentos.
Tipo	Requisito
Prioridad del requisito	Alta/Esencial

Criterios de aceptación: registros de auditoría generados en cada acción crítica.

3.3 Requisitos no funcionales

3.3.1 Seguridad (NFR-SEG)

- NFR-SEG-1: TSL obligatorio en todas las comunicaciones

- NFR-SEG-2: Contraseñas con Hashing seguro (bcrypt)
- NFR-SEG-3: Encriptación de datos sensibles en reposo
- NFR-SEG-4: Control de acceso por rol en backend
- NFR-SEG-5: Protección contra CSRF, XSS, SQL Injection, validación y saneamiento de entrada.
- NFR-SEG-6: Gestión de log segura
- NFR-SEG-7: Políticas de respaldo y recuperación definidos
- NFR-SEG-8: Cumplimiento de normativas de protección de datos personales;
- NFR-SEG-9: Manejo de sesión mediante token de acceso (JWT).

Criterio de aceptación: auditoría de seguridad con checklist y pruebas de penetración sin hallazgos críticos.

3.3.2 Rendimiento (NFR-PERF)

- NFR-PERF-1: Tiempo de respuesta para operaciones CRUD simples < 300 ms bajo carga normal.
- NFR-PERF-2: Página principal cargue en < 2s en conexión promedio móvil.
- NFR-PERF-3: Soporta concurrentes estimados (configurable); por defecto 200 usuarios concurrentes.

Criterios de aceptación: prueba de carga que cumplan los umbrales.

3.3.3 Usabilidad y accesibilidad (NFR-USAB)

- NFR-USAB-1: Interfaces con tipografía legible, contraste adecuado y controles grandes para usuarios mayores.
- NFR-USAB-2: Flujos claros para registro, visualización de exámenes o documentos.
- NFR-USAB-3: Documentación de ayuda contextual y mensajes de errores amigables.
- NFR-USAB-4: Se debe escalar el flujo de acceso a la información en donde primero se accede al paciente y luego visualizar los exámenes médicos de dicho paciente.

Criterios de aceptación: pruebas con usuarios (incluyendo adultos mayores) y score de usabilidad mínimo aceptable.

3.3.4 Disponibilidad y mantenimiento (NFR-DIS)

- NFR-DIS-1: Disponibilidad objetivo 99.5% por mes
- NFR-DIS-2: Actualizaciones con ventana de mantenimiento y migración de datos segura.

3.3.5 Compatibilidad (NFR-COMPAT)

NFR-COMPAT-1: Navegadores modernos (últimas 2 versiones de Chrome, Firefox, Safari y Edge).

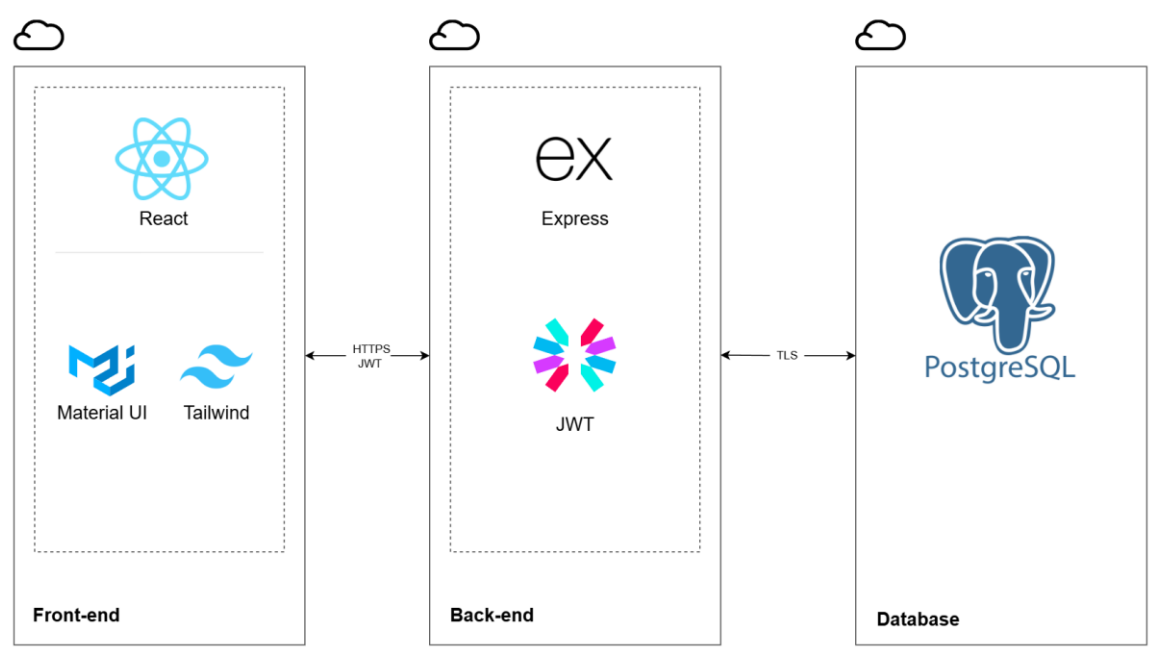
NFR-COMPAT-2: Responsivo para móviles y tablets

3.4 Reglas de negocio (RB)

- RB-1: Un paciente solo tiene permisos de lectura
- RB-2: Un administrador tiene acceso completo a operaciones de escritura, lectura, actualización y eliminación.
- RB-3: Un médico puede ver la información clínica de cualquier paciente registrado.

4. Arquitectura de la solución

El siguiente diagrama despliega conceptualmente como se comunican las capas entre cliente, servidor y almacenamiento junto a la definición de las tecnologías utilizadas.



4.1 Front-end

Dependencias utilizadas en el lado del cliente (principales)

Componente	Versión	Descripción
React	v19.1.1	Biblioteca de Javascript de código abierto utilizado para crear interfaces de usuario interactivas y dinámicas.
Material UI	v7.3.4	Framework de componentes de interfaz (Material UI) que provee diseño y componentes accesibles para React.
Tailwind	v3.4.14	Framework CSS utilitario que permite crear diseños rápidos y consistentes directamente en el HTML/JSX.
axios	v1.13.1	Cliente HTTP para consumir APIs REST, manejar peticiones, respuestas y errores.

4.2 Back-end

Dependencias utilizadas en el lado del servidor (principales)

Componente	Versión	Descripción
Express	V4.19.2	Framework minimalista para construir servidores HTTP y APIs REST. Es la base del backend.
PG	V8.12.0	Cliente oficial de PostgreSQL para Node.js; permite conectarse, ejecutar consultas y manejar transacciones.

Jsonwebtoken	V9.0.2	Implementa el estándar JWT (JSON Web Token) para autenticación basada en tokens.
CORS	V2.8.5	Middleware que habilita CORS (Cross-Origin Resource Sharing) para permitir peticiones desde otros dominios (como el frontend React).